

MQTT Messages Transmitted in Plaintext

Product Name and Version

Product Trueview Security Camera

Model : T18161 S

Firmware: 6.0.23.4

Vulnerability Description

The assessment identified that the device transmitted MQTT communications in plaintext over TCP port 1883. Network traffic analysis revealed human-readable JSON payloads containing device identifiers, message metadata, authentication-related parameters, and operational commands.

The absence of transport-layer encryption allows MQTT messages to be directly observed by an attacker with access to the same network segment.

Impact

An attacker capable of monitoring network traffic may intercept MQTT communications and recover sensitive device information and operational commands without requiring decryption.

Potential impact includes:

- Information Disclosure
 - Exposure of Device Identifiers and Message Metadata
 - Exposure of Operational Commands
 - Leakage of Sensitive MQTT Data
 - Increased Risk of Subsequent Attacks Using Captured Information
-

Proof of Concept (PoC)

The assessment confirmed the following:

- The device exposed an MQTT service on TCP port **1883**.

```

PORT      STATE SERVICE      VERSION
554/tcp    open  ssl/rtsp
1883/tcp   open  mqtt
8888/tcp   open  sun-answerbook?
10010/tcp  open  ssl/rxapi?
2 services unrecognized despite returning data. If you know the ser
=====NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)=====
SF-Port554-TCP:V=7.80%T=SSL%I=7%D=7/22%Time=6A609429P=x86_64-pc-li
SF:%r(SIPOptions,B0,"RTSP/1\0\20200\200K\r\nServer:\20happytime
SF:p\20server\202\2\2\r\nCSeq:\2042\r\nDate:\20Wed\20Jul\2022\
SF:8:05\202026\r\nPublic:\20DESCRIBE.\20SETUP.\20PLAY.\20OPTIO

```

- MQTT traffic was captured using Wireshark.

The image shows a Wireshark packet capture of MQTT traffic. The packet list on the left shows a sequence of MQTT messages and acknowledgments. The packet details pane on the right shows the structure of an MQTT message, including the header, options, and payload. The packet bytes pane at the bottom shows the raw data of the message.

- Captured packets contained readable JSON payloads including:
 - deviceId
 - deviceSecret
 - msgType
 - nonce
 - time
 - sign
 - PTZ control commands (R.PTZ.Control)

```

"msg": {
  "deviceId": "XXXXXXXXXXXXXXXXXXXX",
  "deviceSecret": "xxxxxxxxxxxxxxxxxxxxxxxx",
  "msgType": "thing.action.execute",
  "nonce": "xxxxxxxxxxxxxxxxxxxxxxxx",
  "payload": {
    "data": {
      "actionName": "R.PTZ.Control",
      "id": 20130,
      "inputParams": [
        {
          "paramsName": "Direction",
          "type": 1,
          "value": "{\\Cmd\\\":\\\"MoveLeft\\\",\\\"Arg\\\":1,\\\"Arg2\\\":0}"
        }
      ]
    },
    "msgId": "xxxxxxxxxxxxxxxxxxxxxxxx"
  }
}

```

```
"sys": {  
  "ack": 1  
},  
"time": 1785730151539  
},  
"requestTime": 1785730151,  
"version": "v1"  
},  
"sign": "xxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxxx"  
}
```

- No encryption was required to recover the message contents.

Steps to Reproduce

1. Connect to the same network as the device.
2. Capture MQTT traffic using Wireshark.
3. Perform normal device operations.
4. Observe that MQTT payloads are transmitted as plaintext JSON.

Suggested Mitigation

- Enable MQTT over TLS (MQTTS).
- Encrypt all MQTT communications.
- Avoid transmitting sensitive information in plaintext MQTT payloads.
- Periodically review network services for insecure communication channels.